



TECHNICAL WHITE PAPER

One governed chain from evidence to filing

An AI-native, 21 CFR Part 11-governed regulatory submission platform spanning medical device and drug pathways — from source intake through grounded drafting and assembly to validated agency transmission.

931

TABLES FROM
A BLANK DATABASE

359

REGULATORY
AI TOOLS

13

AGENCY
GATEWAYS

15

DOMAINS UNDER
OUTSIDE AUDIT

Concept2Cure, Inc.

Prepared for prospective investors · August 2026

Assessed against the concept2cure-v2 engineering branch

CONFIDENTIAL
NOT FOR DISTRIBUTION

This paper reports an independent readiness audit of the platform alongside its capabilities, including findings that were unfavourable. Quantitative figures were derived directly from the repository and from that audit's executed evidence. Forward-looking statements regarding roadmap, market conditions, and competitive position are estimates, not guarantees of outcome.

CONTENTS

What this document covers

A technical assessment of the platform as it exists in code today — its architecture, its intelligence layer, the compliance machinery, what an independent audit found wrong with it, and what has been fixed since.

01	Executive summary	03
	The thesis, and the audit that tested it.	
02	The problem and the market window	04
	Four disconnected silos, and the 2026–2029 standards transition that reopens every stack.	
03	The competitive landscape	05
	Who occupies each silo, what they do well, and where each one stops.	
04	Platform architecture	06
	The five-layer stack, and the design decisions that matter commercially.	
05	The intelligence layer	07
	AnA, the AI gateway, and the RIM — a deterministic layer that learns without a model.	
06	Trust architecture	08
	Part 11 mechanisms, tenant isolation, and where each one genuinely stands.	
07	Regulatory coverage	09
	Three journeys over one shared chain: intake to transmission.	
08	Engineering scale and the quality system	10
	What exists, and how architectural invariants are enforced by machine.	
09	The independent readiness audit	11
	15 domains, 32 P0 findings, executed against a live system. Reported without softening.	
10	Remediation, verified	12
	What has closed since the audit, checked in the code rather than taken on report.	
11	Defensibility and moat	13
	Which advantages compound, which are merely current, and which are not yet built.	
12	Roadmap to general availability	14
	A dependency-ordered programme with evidence gates a buyer's reviewers accept.	
13	Risks, and what to underwrite	15
	What could go wrong, and what an investment is actually buying.	

A NOTE ON METHOD

Every quantitative claim here is derived from the repository itself or from an independent audit that produced its findings by running the system — provisioning the database, booting the production build, executing the test suite, and reproducing failures by hand. **Sections 09 and 10 report that audit's unfavourable findings in full.** A vendor selling into regulated life sciences is bought or rejected on whether its claims survive scrutiny, so the claims here are written to be checked.

SECTION 01

Executive summary

Regulatory submission software is fragmented into four silos that no vendor spans. Concept2Cure.RI is built as the spanning layer. An independent audit in August 2026 confirmed both halves of that claim: the architecture is real, and it was not yet trustworthy.

The market failure

Bringing a medical product to market requires assembling evidence, drafting an argument from it, packaging that argument to an agency's exact technical specification, and transmitting it through a validated channel — with every step attributable and defensible years later. That work is split across four categories of vendor that do not talk to each other: evidence and literature platforms, AI authoring startups, publishing and validation incumbents, and regulatory information management systems. Sponsors buy three or four and stitch the seams with consultants.

What has been built

A single governed system spanning that chain. Source documents enter a tenant-isolated evidence store; a retrieval-grounded assistant drafts against them with per-claim citations; the editor refuses to save content lacking clause-level provenance; approval runs through an electronic-signature workflow; and the package is assembled to eCTD or eSTAR structure, validated, and handed to one of thirteen agency transport adapters. On a blank PostgreSQL the installer builds **931 tables and 787 row-level security policies** and exits clean.

What the audit found

A 15-domain independent readiness audit, executed against a live instance on **10 August 2026**, returned **not ready for general availability**: 32 P0 and 106 P1 findings, average domain maturity 4.1 of 10. Its central finding was not absent features but *controls that reported success while doing nothing* — an audit hash-chain that verified an empty chain as intact, RLS policies rendered inert by a superuser database connection, an eCTD compile path that emitted zero leaf files. Section 09 reports this in full.

WHY THAT AUDIT IS IN AN INVESTOR DOCUMENT

Because it is the most informative thing available about this company. It establishes that the architecture is worth keeping — the auditor's own words were "not a facade... a genuinely engineered spine" — and it establishes exactly what the remaining work is. An investor's real question is not whether a pre-GA platform has defects. It is whether the team finds them, reports them, and closes them.

What happened next

In the four days following the audit, **149 commits** landed on the deploy branch, reading as a direct remediation programme. Seven of the audit's most severe mechanisms were independently re-checked in the code for this paper and found closed: the eCTD leaf renderer now emits genuine PDFs, a least-privilege runtime database role is provisioned, the tenant-deletion escape hatch is gone, the AI provenance ledger fails closed at boot, integrity checks now report `unverifiable` honestly, the global test-database mock is gone, and the timer-cancelling frontend defect is removed.

The honest position

The platform remains pre-GA. A first live filing still depends on licensed agency templates, validator licences, gateway credentials, and a quality-system qualification signed by a competent person. The audit's own estimate — a caveated design-partner pilot in 6–8 weeks, a defensible first paying pharma customer in 4–7 months with a 6–9 person team — is the working plan, and Section 12 sets it out.

SECTION 02

The problem and the market window

The submission market is not underserved — it is mis-served, by vendors each solving one quarter of a problem that only makes sense as a whole.

The work, and where it breaks

A regulatory submission is an argument built from evidence, formatted to a specification, and defended under inspection. Four things must hold simultaneously: the evidence must be found and appraised; the argument must be written and cited; the package must conform byte-for-byte to an agency's technical standard; and every step must be attributable to a person and a moment. No single vendor delivers all four, so the handoffs between them are where sponsors lose months — re-keying content between systems, reconciling citations by hand, and discovering conformance failures only at the gateway.

The timing: a mandatory migration reopens every stack

eSTAR v7.0 — mandatory since 3 Aug 2026

Every 510(k) and De Novo now flows through eSTAR. FDA technical-screening error rates fell from 20.5% to 5.4% under it. The *formatting* pain is shrinking; value is migrating to predicate strategy, testing rationale, and clinical evidence — the content problem.

eCTD 4.0 — the 2026–2029 window

PMDA mandatory April 2026, EMA around 2027, FDA around 2028–29. Every sponsor must migrate. Only about four vendors passed the EMA v4 pilot. This is the decade's one industry-wide drop in switching costs.

Gateway access is open

FDA's ESG NextGen retired the legacy WebTrader client in April 2025 in favour of a portal, REST API, and AS2. There is **no FDA certification programme for eCTD software** — validation criteria are published and a new entrant can offer direct submission on sponsor-held accounts after a short test phase.

AI is being normalized — and governed

FDA deployed its own generative system in 2025; FDA and EMA published joint AI guiding principles in January 2026; EU AI Act obligations phase in from August 2026. AI content is becoming acceptable, which turns *governance of the AI* into the procurement question.

What that combination means

A buyer who must migrate to a new submission standard anyway, who is now permitted to use AI but must prove how it is controlled, and who currently pays three vendors to cover one workflow, is a buyer whose stack is genuinely re-openable. That condition does not persist. It closes when the migration completes and the incumbents' AI bolt-ons mature — which is the clock this business is running against, and the reason the remediation programme in Section 12 is sequenced for speed rather than elegance.

THE ONE THING THAT DOES NOT CHANGE

Whatever the standard or the model generation, a submission must be defensible: an inspector, years later, must be able to ask where a sentence came from and receive an answer. That requirement is indifferent to AI progress, and it is the requirement the platform's architecture is organized around. Frontier capability will keep improving for every competitor simultaneously; the ability to prove provenance will not arrive by upgrading a model.

Market facts are drawn from a competitive benchmark synthesized from public agency notices and industry research in August 2026, with per-claim sources retained in the platform's engineering documentation. Vendor capability descriptions reflect publicly stated positioning at that date; pricing is directional and is not reproduced here.

SECTION 03

The competitive landscape

Four silos, on both the device and the drug side, with the same structural boundary in each. The gap is not a niche — it is the middle of the workflow.

SILO	REPRESENTATIVE VENDORS	WHERE IT STOPS
Evidence & literature	Celegence CAPTIS, DistillerSR, CiteMed, Nested Knowledge, Basil Systems	Produces screened evidence and landscape data, not a submission-shaped argument.
AI authoring	Weave Bio, Peer AI, Yseop, Narrativa, Complizen, Cruxi, Essenvia	Stops at the document boundary — no assembly, validation, or transport.
Publishing & validation	Lorenz docuBridge, Extedo, Certara GlobalSubmit, Ennov	Validates and transmits; AI is a workflow bolt-on, not a drafting engine.
RIM & lifecycle	Veeva Vault RIM, Rimsys, RegDesk, Greenlight Guru	Tracks registrations, process, and quality; does not generate the content.

The notable positions

Veeva Vault RIM — the gravity well

Market leader with several hundred RIM organizations and a downmarket SKU. The durable advantage is distribution, not capability: recurring complaints concern speed at scale, a cumbersome data model, and services overhead, and its 2026 AI is workflow agents rather than drafting. This is the incumbent whose response determines the size of the window.

Lorenz — the validation reference

docuBridge plus eValidator, the industry's reference validation tool, and an FDA eCTD 4.0 pilot partner since 2022. Criticised on desktop-era usability. Relevant here as both a benchmark and a dependency: the platform carries an adapter seam for eValidator, and the licence is a procurement item.

Weave Bio — the closest bridge

AI IND drafting extended to NDA workflow in April 2026 via a contract-research channel, with a published sponsor case reporting a large time reduction and no critical errors. It has no assembly, validation, or gateway — the bridge is a services partnership, not a product.

Greenlight Guru — the governance badge

Medtech quality-system incumbent, ISO/IEC 42001 certified — first to make AI governance a marketable credential in this segment. It does not generate or fill eSTAR. Its certification is the clearest signal that *how the AI is governed* has become a purchasing criterion.

The structural finding

Nobody spans intake → evidence → drafting → official package → post-market. The two closest moves are recent and partial: a RIM vendor added authoring-lite in May 2026 with no evidence engine behind it, and an AI authoring startup reached the drug workflow through a CRO channel. Meanwhile a publishing incumbent has stated publicly that it is evaluating the future of its regulatory writing unit — a signal that the services-attached model is under pressure from exactly this direction.

THE HONEST COUNTERWEIGHT

Every vendor above has something this platform does not: paying customers, executed submissions, and a validation history. Architecture spanning the chain is a real advantage only once it is trustworthy enough to be bought, which is what Sections 09 through 12 are about. The competitive claim in this paper is about product shape, not market position.

SECTION 04

Platform architecture

A single TypeScript monorepo organized in five layers, each of which the layer above can only reach through a governed interface.

Surface LAYER 5	React 18 + Vite single-page application. Chat-first : capability is invoked by asking the assistant, not by navigating to a screen per feature. The canonical workspace is an asymmetric three-zone grid — contextual tree, an intelligence stream, and a live-rendered artifact pane that never inherits chat state. A registry of 28 governed components is the single source of truth; raw form elements are rejected by a CI gate.
Governance LAYER 4	The compliance spine, described in Section 06. Audit chaining, electronic signature with signing-authority resolution and version binding, document freeze and lock, clause-level lineage enforced in-transaction, and a default-deny authorization boundary mounted once ahead of all route registration — so no route file can forget authentication.
Intelligence LAYER 3	AnA, the tool-calling regulatory assistant (359 registered tools across 13 capability categories); the AI gateway that every model call must pass through; and the RIM, a deterministic non-LLM layer that accumulates regulatory patterns over time. Detailed in Section 05.
Domain services LAYER 2	217 service domains covering the regulatory subject matter: eCTD assembly and lifecycle operations, eSTAR generation, substantial-equivalence and predicate analysis, clinical evaluation and literature appraisal, biostatistics, CMC, pharmacovigilance, quality management, and thirteen agency transport gateways. Exposed through 3,846 route handlers in 389 modules.
Substrate LAYER 1	PostgreSQL with pgvector, addressed through Drizzle. A fresh-database installer provisions 931 tables and 787 row-level security policies from blank in one idempotent command, takes a cluster-wide lock, re-verifies its readiness contract, and fails closed with a distinct exit code. Object storage for source documents, Redis for cache and queueing, and a real-time collaboration backend for the editor.

Design decisions that matter commercially

Fail-closed by default The server refuses to boot without its secrets and names what is missing. The AI gateway refuses to serve with no provider. The readiness endpoint fails closed on an incomplete schema. A regulated buyer's first question is what the system does when it is wrong.	One of everything An enforced doctrine that there is never more than one implementation of a capability, backed by CI gates rejecting duplicate table definitions, unreachable migrations, and parallel runtime paths. It is why a system of this size stays modifiable.	Refusal as a first-class result When the platform lacks a licensed template, a dataset, or a credential, it says so explicitly rather than approximating. End-to-end journey tests assert honest refusals as passing outcomes. A confident wrong answer is a liability here, not a feature.
--	--	---

WHY A MONOREPO OF THIS DEPTH IS THE ASSET

Regulatory subject matter does not compress. eCTD backbone construction, lifecycle operations, controlled vocabularies, region-specific validation profiles, substantial-equivalence logic, and thirteen distinct agency transport protocols are each irreducibly detailed, and each must interoperate with the governance layer to be usable. The volume of domain code is not incidental scale — it is the barrier a point-solution competitor would have to cross to span the same chain.

SECTION 05

The intelligence layer

Three components: an assistant that acts through governed tools, a gateway that no model call may bypass, and a deterministic layer that learns without a model at all.

AnA — the regulatory assistant

AnA is the product surface. Rather than a chatbot bolted beside a feature set, it is the invocation mechanism for the feature set: **359 tools** spanning submission and eCTD, evidence and intelligence, device and IVD, authoring, clinical, governance, quality management, CMC, nonclinical, biostatistics, and clinical pharmacology. Context is assembled from three memory layers before each turn — the working thread, project memory retrieved by vector similarity, and account context.

Grounding is checked deterministically

After each turn, a self-verification round — no additional model call — extracts the verifiable identifiers from the answer (trial registrations, PMIDs and DOIs, FDA submission numbers) and any quoted source text, and checks each against the evidence the assistant actually gathered that turn. Claims absent from that corpus are surfaced as unsupported. **The verdict is advisory: it is shown to the user, not used to block or rewrite the answer.** Binding retrieval-verified citations into the document itself is Phase 2 work in Section 12.

The AI gateway — a policy chokepoint

Every model call passes through one gateway, and a CI gate rejects code that attempts to bypass it. The gateway performs provider routing and failover, health tracking, cost accounting, and two evaluation passes before dispatch: a synchronous check covering token budget, role-aware prompt-injection scanning, blocked patterns and rate limits; and an asynchronous PII/PHI pass over outbound content that can allow, flag, redact, or block, producing a structured audit verdict that never carries the raw sensitive value.

The provenance ledger behind it — which model, at which temperature, from which prompt, on which substrate, produced each output — was found by the August audit to be silently recording nothing. It now **fails closed at boot** rather than reporting success: the platform refuses to start if the ledger is unreachable, on the reasoning that boot is the one moment where refusing to continue costs nothing already in flight.

Placement — the enterprise unlock

Every provider the gateway can reach is classified by three facts: the substrate it runs on (shared frontier API, frontier-in-your-cloud, or self-hosted), the regions it can be pinned to, and whether it carries a zero-data-retention guarantee. A tenant requiring EU residency can only be routed to a provider whose placement includes the EU; a tenant requiring zero retention only to a substrate contractually capable of it; an air-gapped tenant only to self-hosted inference. This is what makes a large pharmaceutical customer procurable, and it is architectural rather than configurational.

The RIM — accumulating judgment without a model

The Regulatory Intelligence Model sits beneath the assistant and is deliberately **not** an LLM. It observes regulatory work and aggregates signals — recurring deficiencies, reviewer triggers, data gaps, consistency issues — into durable, tenant-scoped patterns whose confidence rises with repeated observation but is bounded, so a single noisy loop can never assert certainty. It is pure and deterministic: no network calls, no wall-clock dependency, identity derived from inputs, so the same call sequence always yields the same state — a prerequisite for anything influencing a governed document.

SECTION 06

Trust architecture

In regulated life sciences, output that cannot be defended under inspection has no value. This section states where each control genuinely stands — including the two the August audit found failing.

Mechanisms, and their actual state

CONTROL	STATE	WHAT IS TRUE TODAY
Electronic signature	BUILT	Server-side credential re-verification, signing-authority and signer-role resolution, binding to a specific document version. The audit called the design right; the remaining work is consolidating to one system of record.
Clause-level lineage	BUILT	The editor cannot save content without clause-level provenance — enforced in-transaction and structurally gated in CI. A user can select any passage and ask where it came from.
Audit chain	IN FLIGHT	Chain enforcement exists on the reference store via an insert trigger. The August audit found the chain unpopulated and three integrity checks reporting an empty chain as intact. Checks now return an explicit unverifiable state; substrate consolidation and immutability grants are Phase 2.
Tenant isolation	IN FLIGHT	787 policies with correct USING/WITH CHECK semantics and FORCE RLS. They were <i>inert</i> because the application connected as a table-owning superuser. A least-privilege <code>app_service</code> role is now provisioned; running production under it is the remaining step.
Authentication boundary	BUILT	Default-deny gate mounted once ahead of all route registration. Algorithm-pinned JWT with CI-enforced rotation, bcrypt at 12 rounds, attempt-limited email OTP. The org-admin privilege escalation the audit exploited is closed.
Qualification pack	GENERATED	Eleven Part 11 controls mapped to the tests that exercise them, all eleven executing and passing, with a verdict that fails closed on any control lacking evidence. Execution and signature require a competent person.

The principle the audit tested

The audit's sharpest observation was not about any single control. It was that several failures shared a shape: *a control that reports success while doing nothing*. An integrity monitor verifying an all-null chain as healthy. A tenant-offboarding path reporting permanent deletion while the data survived. Governed AI commands returning past-tense success for work that never happened. In a regulated tool a silent-pass control is more dangerous than an absent one, because only the first gets relied on during an inspection.

WHAT CHANGED AS A RESULT

The remediation was not only to fix each defect but to make the class detectable: integrity checks that cannot verify now say so; the AI provenance ledger refuses boot rather than logging silently; a CI gate rejects tenant-blind data models — the class behind two of the isolation findings. Fixing an instance closes one finding. Making the shape of the mistake fail loudly closes the ones not yet written.

SECTION 07

Regulatory coverage

Three go-to-market journeys run over one shared chain. The chain is what competitors do not have; the journeys are what customers buy.

01	02	03	04	05	06	07
Intake	Evidence	Draft	Review	Assemble	Validate	Transmit
Canonical source identity, chunking, embedding, project-scoped isolation	Retrieval, literature appraisal, predicate and precedent analysis	Grounded authoring with per-claim citation and lineage gate	Threaded review, approval chain, freeze, electronic signature	eCTD or eSTAR structure, PDF/A rendering, checksum manifest	Structural and regional validation, dispatch-readiness gate	Governed transmission with pre-transmit checks and acknowledgement

The three journeys

JOURNEY	SCOPE	POSITION AGAINST 2026 TABLE STAKES
510(k) / De Novo GATED ON TEMPLATES	FDA device premarket notification. eSTAR generation, predicate identification, substantial-equivalence argumentation, filing readiness.	Substantial-equivalence engine, versioned template registry, product-code-to-consensus-standards mapping, and claim-to-source traceability are live. Multi-user authoring with Part 11 audit exceeds the device-side field. Official template packs and field maps are a procurement gate the system fails closed on.
CER / PER UI WIRING IN FLIGHT	EU MDR and IVDR clinical evaluation. Annex XIV structure, MEDDEV 2.7/1 rev 4 conformance, literature screening, vigilance integration.	Rule packs, conformance validator, governed export renderers, and MAUDE/FAERS clients are real; literature screening decisions now persist with an enforced exclusion rationale. Human-in-the-loop provenance is the decisive advantage — notified bodies reject pure-AI clinical evaluations.
IND / NDA VALIDATOR LICENCE PENDING	Drug submissions via eCTD. Backbone assembly, lifecycle operations, study tagging, US Module 1, PDF/A pipeline, gateway transmission.	The spine-backed path assembles an ICH v3.2.2 backbone with an MD5 manifest and genuine rendered PDF leaves; the legacy draft path marks every leaf rendered="false" and names the blocker rather than emitting an untransmittable package. An adapter seam for the reference validator is ready; the licence is procurement.

Agency transport

Thirteen submission-gateway adapters are implemented — FDA ESG, EMA CESP, PMDA, MHRA, Health Canada, TGA eBS, Swissmedic, NMPA, MFDS, ANVISA, CDSCO Sugam, HSA PRISM — behind a single governed transmit path with pre-transmit checks, bundle-integrity verification, and acknowledgement tracking. Because there is no FDA certification programme for eCTD software, direct gateway submission on sponsor-held accounts is reachable without an incumbent's permission.

THE STRUCTURAL POINT

A competitor entering from the authoring side must build assembly, validation, and transport before it can span the chain. One entering from the publishing side must build grounded drafting and the governance to make AI output defensible. Both must then do it twice — once for device, once for drug. That double crossing is the moat.

SECTION 08

Engineering scale and the quality system

Scale alone is not an asset. Scale that stays modifiable, under mechanical invariant enforcement, in a domain that cannot be compressed — that is an asset.

What exists, counted

DIMENSION	MEASURE	NOTE
TypeScript modules / lines	5,053 / 1.44M	~1.64M lines across 7,805 files counting all languages
Tables provisioned from blank	931	Single idempotent installer, verified exit 0
Row-level security policies	787	Correct USING / WITH CHECK semantics, FORCE RLS
API route handlers / modules	3,846 / 389	Behind a global default-deny boundary
Domain service directories	217	Regulatory subject matter, not framework code
Registered AnA tools	359	Across 13 capability categories
Test files / assertions passing	1,759 / 18,145	8 failing, 95 skipped at audit date
CI guard scripts / workflows	79 / 19	Governance, security, and schema-integrity gates
TypeScript error debt	2,598 → 0	Held at zero by a no-regression gate

Invariants enforced by machine

The CI guard scripts are the unusual asset. They do not check style; they check architectural invariants that would otherwise decay silently — that no code bypasses the AI gateway, that the editor's save path cannot skip the lineage gate, that data models are not tenant-blind, that no duplicate table definitions exist, that migrations are reachable, that no mock data or development authentication path reaches production, that JWT verification stays algorithm-pinned, that interface compliance claims are qualified, and that the completion ledger cannot claim done without evidence.

WHERE THE QUALITY SYSTEM WAS ITSELF WEAK

The August audit's most consequential finding was about this layer: a global database mock installed across all test files meant the two "database-backed, safety-critical" jobs ran against a stub, measured coverage sat at 5–13% on the request path, and no CI job ever ran in the RLS-enforced mode production mandates. That is why the other blockers shipped green. The mock is now gone and golden-journey tests drive all three regulatory journeys end to end — but raising coverage and making the browser tier real remain open, and the audit rightly called this the single highest-leverage investment because it protects every other fix.

What the auditor said was worth protecting

Faithful regulatory outlines — PMA against 21 CFR 814.20(b), EU CTA against CTR 536/2014, MDR Annex II, CTD Modules 2–5 — judged better than most competitors' first attempts. Correct biostatistics: the Lan-DeMets solver reproduces textbook O'Brien-Fleming and Pocock boundaries exactly. Exemplary licensed-terminology handling, failing closed with an explicit licence requirement rather than risking copyright exposure. And what the audit called institutional honesty in the code: endpoints that refuse to self-certify, and comments that name their own gaps.

SECTION 09

The independent readiness audit

On 10 August 2026 the platform was audited across fifteen domains by running it, not by reading it. The verdict was not ready for general availability. This section reports that finding without softening.

32	106	4.1/10	15
P0 FINDINGS BLOCK ANY USE	P1 FINDINGS BLOCK GA	AVERAGE DOMAIN MATURITY	DOMAINS INDEPENDENTLY AUDITED

How it was conducted

Each domain was audited by an independent pass that read the code, ran commands, and queried a live database; every P0 and P1 was routed to an adversarial cross-check whose default was to refute. The most severe findings were then reproduced by hand against a from-scratch 931-table PostgreSQL instance, the production build booted from `dist/`, and the full test suite executed. No repository report or summary was accepted as evidence.

The eight blocker themes

THEME	THE FINDING, AS REPRODUCED
1 · Tenant isolation inert	787 policies were real but bypassed — the app connected as a table-owning superuser. Self-service signup minted an org admin that an escape hatch in <code>requireRole</code> accepted, allowing one tenant to delete another outright.
2 · Part 11 trail untrustworthy	Detection, prevention, and attestation each failed — two by reporting success. The hash chain was never written; the canonical tables permitted <code>UPDATE</code> and <code>DELETE</code> ; the signed inspector export called the empty chain intact.
3 · Production could not boot	Production hard-requires RLS enforcement; with it unset the boot assertion refused, and with it on an unscoped startup probe tripped the very guard it should pass. No flag value yielded a serving process.
4 · Two key jobs unfinishable	The eCTD compile path declared leaf rendering unimplemented and emitted zero files; the review step returned 500 on missing tables; exports were tag-stripped plain text.
5 · AI output undefendable	The gateway's provenance ledger recorded nothing while reporting success; "grounded" meant the model had tagged its own sentence; models were pinned to floating aliases with no reproducible request record.
6 · Privacy lifecycle missing	Right-to-erasure reached 4 of 302 user-linked tables; no data residency; an unencrypted database dump written into an un-ignored directory by a deploy script.
7 · Tests proved less than claimed	A global database mock across all test files meant the safety-critical jobs ran against a stub. Real coverage 5–13%. No job ever ran in the RLS-enforced mode.
8 · Honesty gaps	18 handlers converted internal failures into HTTP 200 with an empty list; 85 queried tables did not exist after provisioning while two CI guards reported green because they compared the repo to itself.

THE AUDITOR'S OWN SUMMARY

"This is not a teardown of a facade. A capable team built a real system; the gap is between the architecture (good) and its wiring, coverage, and operational reality (not yet)." Its estimate: roughly 4–7 months of focused work by a 6–9 person team to a defensible first paying customer — not a rewrite, but a serious hardening programme on a foundation worth keeping.

SECTION 10

Remediation, verified

In the days following the audit, 149 commits landed on the deploy branch. The mechanisms below were re-checked directly in the code for this paper rather than taken from a status report.

AUDIT FINDING	STATE	WHAT IS IN THE CODE NOW
eCTD emitted zero leaf files	CLOSED	The unimplemented flag is gone. A deterministic leaf renderer produces genuine, valid PDF bytes with byte-identical output across re-renders — which is what keeps the MD5 in each granule's index stable. The spine-backed path assembles a real ICH v3.2.2 package; the legacy path declares its leaves unrendered rather than pretending.
App connected as a superuser, making RLS inert	PROVISIONED	A dedicated least-privilege app_service login role is provisioned by the installer and its grants refreshed on every deploy. Running production under that role is the remaining operational step.
Any signup could delete any tenant	CLOSED	The unconditional org-admin escape hatch is scoped so a guard asking for a platform role can never receive an org-admin stand-in. Tenant-management routes are behind a platform-admin middleware with no bypass.
AI provenance ledger recorded nothing	CLOSED	A boot invariant fails the platform closed if the ledger is unreachable, with the per-call writer deliberately left non-blocking so an audit-store outage cannot take inference down.
Integrity checks called an empty chain healthy	CLOSED	The integrity service now returns an explicit unverifiable state with a stated reason when seals cannot be checked, and the Part 11 surface no longer asserts integrity it never verified.
Global database mock across all tests	CLOSED	The mock is gone from the shared setup. Golden-journey tests now drive all three regulatory journeys end to end, asserting honest refusals as first-class passing outcomes.
Frontend cancelled every timer every 60s	CLOSED	The brute-force timer optimizer is removed; client error reporting is wired.

Beyond the specific fixes

The commit record over the same period reads as a programme rather than a patch run: a CI gate that rejects tenant-blind data models — the class behind two isolation findings; an executed IQ/OQ qualification pack generated from what is actually installed and tested; a path-containment ratchet closing six routes; organization scoping on the AI idempotency cache; and persistence for literature screening decisions with an enforced exclusion rationale.

WHAT HAS NOT CLOSED

Audit-substrate consolidation and database-enforced immutability remain in flight. Test coverage on the request path is still low and the browser tier is still thin. Retrieval-verified citation binding, the privacy lifecycle, data residency, and outcome-data capture are not built. Production has not yet been proven to boot and serve under enforced isolation — the single most important remaining gate, and the first item in Section 12.

SECTION 11

Defensibility and moat

Four candidate advantages, sorted honestly by whether they compound, whether they are merely current, and whether they exist yet.

1 · The spanning architecture BUILT

Intake through transmission, governed end to end, across device and drug. The volume of irreducible domain code is the barrier, and it is already paid for. This is a *durable but not compounding* advantage: a well-funded competitor could cross it, but not quickly, and not without doing it twice.

2 · Governed provenance BUILT

Clause-level lineage enforced in-transaction, with a save path that structurally cannot skip it. Retrofitting this into an existing authoring product means rewriting its persistence layer — which is why the AI authoring entrants are unlikely to add it and the publishing incumbents are unlikely to add drafting.

3 · Placement-aware inference BUILT

Residency, retention, and air-gap constraints resolved per tenant at routing time. The prerequisite for large-pharma procurement. Currently differentiating, but *replicable* — expect it to become table stakes within two years as the EU AI Act phase-in makes it a standard question.

4 · Outcome data NOT BUILT

Pairs of submitted content and the agency's actual response. The only advantage here that genuinely compounds, and the only one no competitor can purchase. **Nothing captures it today.** It is designed for and it is the highest-leverage open item on the roadmap.

The compounding asset, stated precisely

Frontier model capability is available to every competitor on identical terms and improves for all of them simultaneously; no durable advantage can rest on it. What can compound is a deterministic, tenant-scoped, versioned record of what regulatory reviewers actually objected to, accumulated across customers and submissions. The RIM is the substrate designed to hold that record — and the substrate had to be trustworthy before the data was worth collecting, which is the correct ordering but means the moat is under construction rather than in place.

What is not a moat

Three things are worth naming as *not* defensible, because an investor will test them. The tool count is a capability inventory, not a barrier — a competitor with the same model access can add tools. The line count is a measure of surface area, and the audit demonstrated that surface area without coverage is a liability as much as an asset. And the design system, while genuinely good, is a matter of taste that any well-resourced team can match. The defensibility argument rests on the four items above and on the switching-cost window, not on scale.

THE HONEST ASYMMETRY

Items 1, 2 and 3 are built and real. Item 4 — the only one that compounds — is not. An investment here is a bet that the team converts a strong architectural position into the operational trustworthiness required to acquire customers, and then converts those customers into the outcome dataset that makes the position permanent. Both conversions are execution, and the audit is the best available evidence of how this team executes when told it is wrong.

SECTION 12

Roadmap to general availability

Sequenced so each phase unblocks the next and produces evidence a buyer's reviewers accept. This is a dependency order, not a wish-list, and it is the audit's own programme.

PHASE	GOAL	PRINCIPAL WORK AND ITS EVIDENCE GATE
0 LARGELY DONE	Stop the bleeding, and make CI tell the truth Weeks 1-2	Close the tenant-deletion path, rotate the exposed credential, remove the unencrypted dump, scope the test database mock, remove the timer optimizer, fix the SSO redirect and MFA token-class bypass. Gate: every later fix becomes provable. Verified closed in Section 10.
1 IN FLIGHT	Make isolation real, and make it boot Weeks 3-8	Run under the least-privilege role; fix the tables that would then deny-all; add residual tenant keys to route-reachable orphan tables; fix the startup posture probe so production boots under enforcement; supply full environment in every deploy target; move submission output to durable storage. Gate: a CI job boots the built image in production mode and asserts readiness returns 200.
2 BEGUN	Make the regulated core trustworthy Weeks 6-16	Land chain and immutability on the durable applier; enforce immutability with triggers and revoked grants; serialize chain writes; consolidate to one signature system of record; replace advisory grounding with retrieval-verified citation binding; pin dated model snapshots. Gate: an independent Part 11 gap assessment against the deployed schema.
3 NEXT	Make one journey actually complete Weeks 10-22	One eCTD pathway emitting a conformant sequence that passes an external validator; ship the review loop; correct filing-type to pathway mapping; expose what is built in navigation; build the privacy lifecycle. Gate: an automated golden journey that reopens the package and validates it.
4 BEFORE GA	Earn the outside signatures	Third-party penetration test; independent Part 11 gap assessment; restore-from-backup drill with documented objectives; raised coverage floors and a real browser tier; a VPAT passing WCAG 2.2 AA; close the licensing and supply-chain gaps. Gate: evidence a buyer's security, quality, and regulatory teams accept on paper.

Procurement, running in parallel

Independent of engineering: official eSTAR templates and field maps, eCTD document type definitions, the reference validator licence, agency gateway credentials, and a medical terminology dictionary licence. These are single-source and the platform correctly refuses to approximate them — which converts part of the timeline from an engineering problem into a commercial one and should be underwritten as such.

REALISTIC TIMELINE

A friendly, single-tenant, caveated design-partner pilot is reachable at the end of Phase 1. A defensible first paying multi-tenant pharma customer — one whose quality and security teams sign off — is the full programme, estimated at 4-7 months with a 6-9 person team. The variance sits in validation and third-party evidence, which is calendar-bound rather than effort-bound: more engineers do not shorten a penetration test or a qualification signature.

SECTION 13

Risks, and what to underwrite

What could go wrong, stated at the same standard as the rest of this document.

Execution risk on trustworthiness

The audit found 32 P0 findings, and while the most severe are closed, the regulated core is not yet through Phase 2. The risk is not that the work is unknown — it is scoped — but that hardening programmes routinely take longer than estimated, and this one is on a clock set by the standards migration.

Procurement dependency

Licensed templates, validator licences, and gateway credentials are single-source. No amount of engineering conjures them, and the platform is designed to refuse rather than approximate. A delay here delays a first filing regardless of code readiness.

Incumbent response

The largest RIM vendors began shipping AI agents in 2026. Their advantage is distribution into accounts this platform must win from outside. The window in which their AI is a workflow bolt-on rather than a drafting engine is finite and not controlled by this company.

Breadth versus depth

Spanning device and drug is the differentiator and also the execution risk. The audit's judgment — make one journey complete before broadening — is the right sequencing, and it means near-term progress will look narrower than the platform's eventual scope.

Validation is a recurring cost

Regulated customers require vendor validation evidence, refreshed as the product changes. This is an ongoing operational burden on every release, not a one-time engineering task, and it structurally slows shipping velocity after GA.

No commercial proof yet

This paper contains no revenue, pipeline, or customer figures because none are derivable from the codebase. The technical case stands on its own; the commercial case is a separate diligence item and should be requested separately.

What an investment is buying

A spanning architecture in a market of point tools, built against a standards migration that has forced every sponsor's stack open, with the domain depth already paid for and the remaining work scoped by an independent audit rather than estimated internally. What it is not buying is a finished product: the platform is pre-GA, its regulated core is mid-hardening, and the compounding data moat is designed but not collecting.

IN SUMMARY

What has been built is the hard part: a governed chain from source evidence to transmitted submission, with provenance enforced structurally rather than by policy, across both regulatory worlds. What was wrong with it has been independently found, published here rather than buried, and is being closed at a measurable rate. The market is fragmented, the migration has forced it open, and the architecture that spans it exists in code today — the question is execution against a known list, on a clock, and that is the risk being priced.